AEGIS: No Tool Call Left Unchecked — A Pre-Execution Firewall and Audit Layer for AI Agents

Aojie Yuan
University of Southern California
Los Angeles, California, USA
aojieyua@usc.edu

Zhiyuan Su
University of California, Davis
Davis, California, USA
azysu@ucdavis.edu

Yue Zhao
University of Southern California
Los Angeles, California, USA
yue.z@usc.edu

ABSTRACT

AI agents increasingly execute tool calls—database queries, shell commands, file operations, and HTTP requests—yet most agent frameworks forward these calls to execution with no pre-execution mediation. Post-execution observability can record what an agent did; it cannot stop it.

We demonstrate Aegis, a pre-execution firewall and audit layer that inserts a framework-agnostic control point between an agent's tool-call decision and its execution.[1] Integration is two lines and supports 15 agent frameworks across Python, JavaScript, and Go. Each intercepted call is decided by layers ordered by what they may observe—pattern rules over the call string, a behavioural anomaly stack over the agent's own history, an instruction-provenance check over the conversation's trust channels, and a declarative policy over all of their facts—returning `allow`, `block`, or `pending`; pending calls suspend the agent and route to a human approval queue. Every decision is Ed25519-signed and linked into a SHA-256 hash chain. The same gateway is driven, in an appendix, by nineteen harnesses—plain SDK loops in three languages, six open-source frameworks, the OpenAI Agents SDK, the Claude Agent SDK, Google's GenAI SDK, a locally served RL-trained model, and the MCP and egress-proxy transports—through the same three scenarios.

The demonstration is live and adversarial. Attendees drive a real agent on a laptop: they watch a benign call clear in about a millisecond, then submit input that genuinely fools the agent into emitting a destructive query and watch the block return *in-band*, so the agent explains what happened and offers an alternative instead of failing. They then pass an approval decision between two people at two laptops while the agent waits. They are invited to try to get a payload past the rules, to tamper with the exported audit log and watch verification fail, and to install the two-line integration into their own agent.

This version also corrects our earlier evaluation. The 99.9% block rate and 0.09% false-positive rate previously reported came from a static per-call benchmark whose construction we audit here and find degenerate; they are withdrawn. Measured instead on tool calls a live agent was actually manipulated into emitting, the pattern layer fires on **0.4%**, because a successful indirect injection produces a syntactically ordinary call. We are explicit about this in the demonstration itself, and the audit reproduces in one command.

KEYWORDS

AI Agent Safety, Tool-Call Interception, LLM Guardrails, Runtime Compliance

1 INTRODUCTION

AI agents do not only generate text; they take actions. ReAct [20] showed that LLMs can interleave reasoning with tool invocations, and modern frameworks such as LangChain [4], CrewAI [5], and LlamaIndex [17] have made tool-augmented agents widely accessible. However, these capabilities create a direct path from model output to real-world side effects—a path that can be triggered by adversarial prompt injection [8] or hallucinated reasoning. In most current stacks, once the model emits a tool call, the framework forwards it to execution with no pre-execution control point.

Post-execution observability platforms such as Langfuse [15] and Arize [1] can record these events, but they cannot prevent side effects before they occur. Existing defenses sit at two extremes: rule-based layers are fast (<1 ms) but brittle against unseen attack patterns, while LLM-judge layers generalize well but add seconds of latency per call.

We demonstrate Aegis, a pre-execution firewall that bridges this gap with a **cost-aware cascade** and, more importantly for a demonstration, with a control point an attendee can stand in front of and try to defeat.

What the demonstration shows. Three scenarios on a laptop (§3), driven live by attendees rather than replayed. A benign call clears in about a millisecond, so the cost of mediation when nothing is wrong is visible before any blocking is. An attendee then asks for a routine-looking install and the agent emits a remote script piped to `sh`; the call is blocked at L1, and the refusal returns *in-band* as a tool result, so the agent explains what was blocked and offers an alternative rather than failing—the single most common objection to pre-execution blocking, answered by watching it not happen. Finally a call marked `require_approval` suspends the agent mid-turn and routes to a second attendee at a second laptop, who allows or blocks it while the first watches their agent wait.

Attendees are invited to attack it: to get a payload past the rules, to tamper with a signed audit record and watch verification fail, and to install the two-line integration into their own agent on their own machine.

Why this version differs. An earlier version of this paper reported that the cascade blocks 99.9% of attacks at 0.09% false positives, outperforming every standalone LLM judge on every metric. Those numbers came from a static per-call benchmark we assembled ourselves, and auditing its construction shows the benchmark cannot support them (§4). They are withdrawn.

We think a demonstration is the right place to say so rather than the wrong one. The system's contribution is the control point—the

[1] Open-source (MIT). Code and demo video: https://github.com/Justin0504/Aegis.

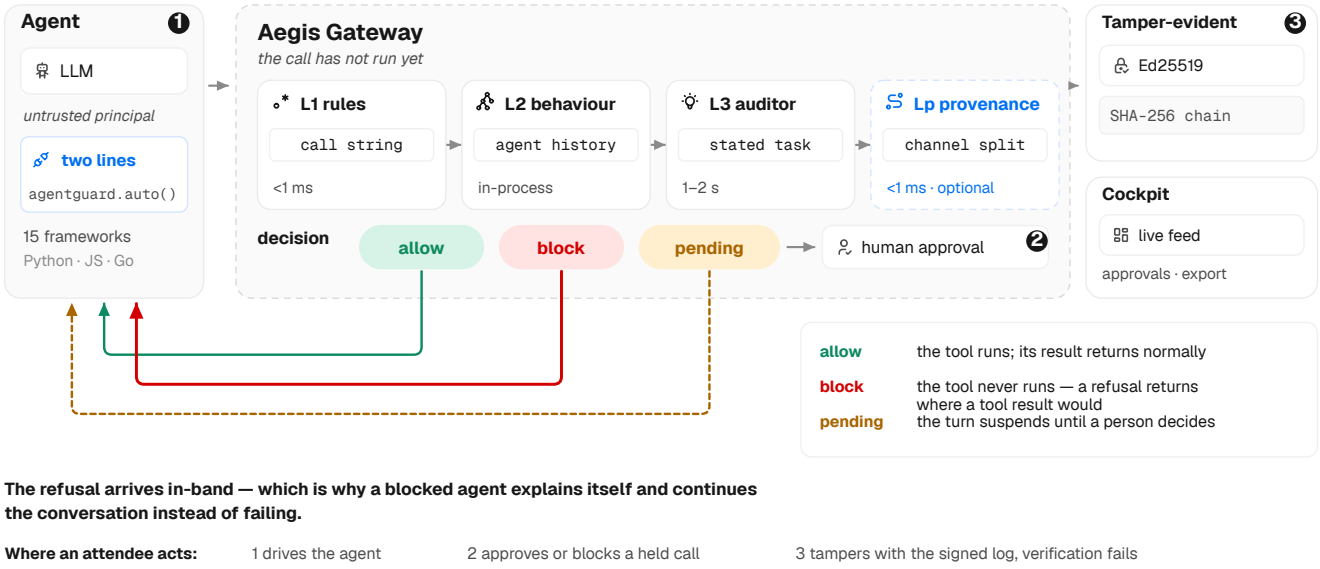


Figure 1: Aegis on the tool-execution path, drawn as the loop it is. Outbound, the SDK intercepts `tool_use` across 15 frameworks and the Gateway applies layers ordered by *observation scope* rather than only by cost: L1 sees the call string, L2 the agent's own history, L_p the conversation's trust channels, and the alignment auditor (L3) the user's stated task. L_p (dashed) is the instruction-provenance layer of §4, optional and toggleable during the demonstration; L3 is not an inline stage of the check but an SDK-side pre-check and a post-hoc trace judge. Inbound is what distinguishes a control point from a monitor: `allow` lets the tool run, `block` returns a refusal *in the slot a tool result would occupy*—which is why a blocked agent explains itself and continues rather than failing (Figure 5(b))—and `pending` suspends the turn until a person decides. Circled numbers mark the three places an attendee acts. Every decision is Ed25519-signed and hash-chained.

fact that a decision can be taken before a side effect, returned in-band, escalated to a person, and signed into a chain—and that contribution does not depend on the detector behind it being good. The detector we ship is good at payloads and, as §4 reports on tool calls a live agent was actually manipulated into emitting, poor at intentions. The demonstration includes an activity where attendees produce exactly that failure on purpose.

Our contributions are:

(1) A **framework-agnostic interception layer** supporting 15 agent frameworks across Python, JavaScript, and Go with two-line integration, returning allow/block/pending before any side effect.
(2) **Human-in-the-loop control and tamper-evident audit**: agents suspend on `pending` and resume on a human decision; every trace is signed (Ed25519) and hash-chained, and verification is offline and checkable by an attendee.
(3) A **live, adversarial demonstration** in which attendees drive the agent, attempt evasion, exercise the approval path across two people, and install the system themselves.
(4) A **compatibility matrix** (Appendix A): nineteen harnesses—open-source frameworks, lightweight and self-hosted agents, closed harnesses including the OpenAI Agents SDK and the Claude Agent SDK, and the MCP and egress-proxy transports—driving the shipping gateway through the same three scenarios, with the twenty-one defects the exercise found and fixed.
(5) An **honest scoping of what the cascade catches**, including a reproducible audit that withdraws this paper's earlier headline numbers and a measurement of what payload inspection achieves against real agent-emitted attacks.

2 SYSTEM ARCHITECTURE

Aegis is organised around one commitment: every tool call an agent emits passes through a point at which it can be decided on, and that decision is returned to the agent in-band, before any side effect occurs. This section follows a single call through the system (Figure 1): how it is captured, what each layer may observe about it, how a policy turns those observations into a decision, what happens when a person must be involved, and how the whole episode is made auditable afterwards.

2.1 Threat Model and Trust Boundary

The LLM is an *untrusted component*. It may emit a harmful tool call because its context was poisoned by indirect prompt injection [8], because it hallucinated an action, or because it was jailbroken. Nothing the model writes is treated as an authority. The trust boundary runs between two channels of the agent's context: what

the *principal* typed, and everything that entered from outside—tool returns, retrieved documents, fetched pages, email bodies. A tool return is untrusted even when the tool is one the operator wrote and the server is one the operator runs, because the content it carries may not be theirs. The SDK and Gateway are trusted enforcement components; Aegis does not defend against an agent that bypasses the SDK entirely, and it does not defend the gateway host.

2.2 Interposition: Three Ways In, One Gateway

SDK instrumentation. The primary path patches the model client at import time:

```
import agentguard
agentguard.auto()  # patches every detected SDK in-process
```

`auto()` wraps the request method of each model client it finds—Anthropic and OpenAI (sync and async), LangChain and LangGraph (through `langchain_core` tools), CrewAI, AutoGen, Gemini, Bedrock, Mistral, LiteLLM, LlamaIndex, Pydantic AI, smolagents [13], the OpenAI Agents SDK (at the tool), the Claude Agent SDK, and a generic HTTP-tool shim; fifteen targets—and exposes two hooks. On the *response* side it extracts every `tool_use` block, sends `(tool_name, arguments, session_id)` to the Gateway, and suspends dispatch until a decision returns. On the *request* side, which is new in this version, it reads the outgoing `messages` array and classifies each span by trust channel before the model is called (§2.3). The agent's code, prompts and tool definitions are untouched. Where the decision is *enforced* is a switch, `enforce_at`: at the response, the SDK raises out of the model call before dispatch; at the tool, the model-level patch only observes and a tool-level patch on the framework's own dispatch method (LangGraph, CrewAI, AutoGen, LlamaIndex, smolagents, Pydantic AI, the OpenAI Agents SDK) returns the refusal as the tool's result, so the model sees it in the slot a result would occupy. A stack with no such method to patch—a hand-written loop, LiteLLM, the Google GenAI client—gets the same behaviour from one line that wraps its dispatcher, `agentguard.guarded(execute_tool)`. The JavaScript SDK patches Anthropic, OpenAI and LangChain and ships the same `enforceAt` switch and `guarded` helper; the Go SDK is an explicit `Wrap(tool, args, fn)` that checks, holds, runs and traces.

MCP proxy. For agents that reach tools over the Model Context Protocol, a stdio or HTTP proxy sits between the host and the MCP server, forwards `tools/call` requests through schema validation, L1 and the policy DSL in-process, with the kill switch, and rewrites refused calls into tool errors. Nothing in the host changes.

Egress proxy. For stacks where neither is available, the gateway accepts the model provider's own API surface at `/api/v1/proxy`, so pointing `OPENAI_BASE_URL` or its equivalent at Aegis is a complete integration. The proxy decides inline: it runs the detector chain of §2.3 and the tenant's policy over every tool call in the model's response, and because an inline HTTP response cannot be held for a person, a `pending` decision is treated as `block` and the audit record says so. A policy is written once and applies on all three paths; the behavioural and provenance layers below run on the SDK path, which reaches the full `/api/v1/check` pipeline.

2.3 The Decision Pipeline

A call that reaches `/api/v1/check` is decided by layers ordered by *what each may observe*, not only by cost. The ordering matters because the measurement in §4 turns on it: layers that see only the call string are blind to a class of attack that layers which see the conversation can resolve.

Identity and scope. Before any content is read, the call is attributed. The agent is looked up in the registry (and created on first sight), an agent the operator has suspended or the kill switch has revoked is refused, and an agent with a *declared tool scope* may only call the tools it declared: a call to an undeclared tool is blocked as `unattested-tool` before extraction. Scope is opt-in per agent, so an unscoped agent is not blocked by a check it never asked for.

Extraction. Arguments are walked recursively (depth limit 32, 10,000-string cap) and every string-bearing leaf is collected. This is what L1 sees.

L1: pattern rules (<1 ms). 28 risk patterns in 11 types (Table 2) are matched against the extracted strings. A hit is an immediate block with a named reason. L1 is the right tool for a *payload* that is itself hostile—a SQL statement with a stacked `DROP`, a path with `../`, a shell string with `${IFS}`—and, as §4 shows, nearly inert against a call whose arguments are ordinary.

L2: behavioural anomaly (in-process). Rather than a second look at the call string, L2 scores the call against the agent's own history. A 16-dimensional behaviour vector—tool novelty, frequency and recency; argument drift (Jaccard distance, length z-score, key-count ratio); hour and interval deviation; burst ratio; sequence surprise under a PPM-C model and bigram unlikeliness; cost z-score; risk ordinal and high-risk rate—is scored by an Isolation Forest [22], half-space trees and Mahalanobis distance, calibrated into conformal p-values, with ADWIN [3] flagging drift so thresholds adapt rather than decay. A new agent is cold-started from its tenant's aggregate baseline, and operator approve/reject feedback is folded back into the scorer. L2 can escalate or block an otherwise-allowed call and never relaxes one. It catches an agent behaving unlike itself; it does not catch a single ordinary-looking call, and §4 measures that limit directly: on the rebuilt corpus no surface feature of the call (Table 1) exceeds AUC 0.585, because a successful injection does not make the call look unusual.

Detector chain (proxy path). On the egress proxy the same facts are produced by a registry of pluggable detectors keyed to an ATT&CK-style agent threat ontology: indirect prompt injection, data exfiltration, sensitive-context exfiltration by taint tracking (the agent read a secret, then calls outward), memory poisoning (instruction-shaped writes to scratchpads and vector stores), reconnaissance, lateral movement, tool scope against an agent's declared tool list, budget, cross-agent correlation and PII, with the L1 classifier and the L2 stack wrapped as detectors of the same interface. Operators register their own, and a coverage map reports which ontology techniques the deployed set actually covers.

L_p: instruction provenance (<1 ms). This layer asks a different question: not what the call contains but *which turn authorised it.* The Gateway keeps a per-session *context ledger*—a bounded record

(64 events, 256 KB) of every span that entered the agent's context, tagged `user`, `untrusted` or `model`—populated by the SDK's request-side hook. Four grounded features are computed from the ledger and the call: `user_licence` and `untrusted_licence`, the fraction of the call's vocabulary (tool name split on case, argument keys, argument values) that each channel accounts for; `authority_margin`, their difference; and `tool_named_in_untrusted`, whether untrusted text names the tool being called and the principal does not. The licence measure is asymmetric by design—it scores how much of the *call* a channel explains, not how similar two texts are—which is what makes the obvious evasion (copying the user's request into the injection) inert (§4). The result is a verdict in {`user`, `untrusted`, `unclear`, `unknown`} (Figure 2). `unknown` is reported, never inferred: a session with no reported user turn yields it, and every provenance rule in the shipped policy pack requires a decided verdict, so an un-instrumented deployment sees no behaviour change rather than a wall of false blocks. Ledgers are namespaced by tenant; without that, an attacker who guessed a session id could write a `user` event into another tenant's session and launder an injected instruction into an authority.

L3: alignment auditor (1–2 s). A frontier model receives the tool name, arguments and the user's stated task and returns whether the call serves that task, with a rationale. In the shipping gateway this is not an inline stage of the check: the SDK may call the auditor (`/api/v1/alignment/check`) before the check and attach its verdict, which the policy can match on (`alignment.score`); and a trace judge scores recorded traces after the fact. The judge of §4 is the evaluation harness's own, run as a detector over the corpus; it makes the same comparison, and it is the only configuration meaningfully above chance on real injected calls before L_p existed. Its cost is roughly 1600× the rules path.

Policy. The layers emit facts; a declarative policy turns facts into a decision. Policies are written in a small DSL over dotted field paths— `tool.name`, `classifier.category`, `anomaly.score`, `alignment.score`, `provenance.authorised_by`—with `all`, `any` and `not` composition, and comparators including regular expressions. The DSL is *fail-safe*: a rule can tighten a decision (allow → pending → block) and can never relax a block imposed by schema validation or anomaly detection to allow. Rules are compiled once per tenant and evaluated in constant time per call. Eight packs ship ready-made—GLBA, PCI DSS, SOX, DORA, HIPAA, FedRAMP, a fintech agent-payments pack, and the instruction-provenance pack of §4—each carrying a citation to the clause it addresses so an auditor can cross-check. A natural-language compiler drafts DSL from prose for operators who do not want to write it by hand; the compiled rule, not the prose, is what runs.

Decision. The call resolves to one of three outcomes, each with a distinct return path. `allow`: the tool runs and its result returns normally. `block`: the tool never runs, and a structured refusal is returned *in the slot a tool result would have occupied*—which is why a blocked agent explains itself and continues the conversation rather than failing (Figure 5). `pending`: the turn suspends until a person decides.

Table 1: The fifteen content features used as the *content* block in §4.4. They describe the call string only; on agent-emitted attacks none exceeds AUC 0.585.

#	Feature	Description
1	arg_count	Number of top-level arguments
2	total_arg_chars	Total character count
3	max_string_depth	Deepest nesting level
4	url_count	URLs in arguments
5	ip_literal_count	Raw IP addresses
6	digit_ratio	Fraction of digit characters
7	uppercase_ratio	Fraction of uppercase chars
8	punct_ratio	Fraction of punctuation
9	json_depth	JSON nesting depth
10	has_path_sep	Contains / or \
11	has_curly_braces	Contains { or }
12	shannon_entropy	Bits per character
13	longest_run	Longest repeated character run
14	base64_like	Base64 heuristic score [0,1]
15	hex_like	Hex string heuristic [0,1]

Table 2: L1 risk patterns as shipped (28 entries, 11 risk types). PII (11 types) is detected separately, in traces and by the proxy's detector chain.

Risk type	#	Techniques covered
SQL injection	7	OR/UNION, blind (pg_sleep, WAITFOR, BENCHMARK, SLEEP), hex, CONCAT, stacked
Path traversal	4	../, URL-encoded, double-encoded, null byte
Shell injection	4	Metachar, curl/wget+URL, ${IFS} splitting, process subst.
Sensitive files	1	11 paths: passwd, shadow, .ssh, .aws, .kube, .terraform, .env
Prompt injection	1	17 sub-patterns: ignore/forget/ jailbreak/DAN/bypass/roleplay
Data exfiltration	2	Large payload; payload + external URL
Plaintext URL	1	Unencrypted endpoint in arguments
Supply chain	8	Source-map leak (3), unsafe publish (3), secret in build (2)

2.4 Human-in-the-Loop, Containment, and Learning

A `pending` decision places the call, its arguments, every layer's facts and the matched rule in an approval queue; the agent polls and resumes within one cycle (2 s) of a person choosing Allow or Block, and a hold that nobody decides expires after ten minutes as a block. Three controls contain an *agent* rather than a call. A *kill switch* revokes an agent's access after a configurable violation count, so an agent that is being repeatedly manipulated is stopped rather than argued with one call at a time. A *budget guard* bounds spend per day, month, agent and session in dollars, with a configured action of `log`, `warn` or `block`. For actions that cannot be undone—sending mail, moving money, posting publicly—an *effect outbox* holds an allowed call for a configurable window in which an operator can still cancel it, so even an allowed irreversible action keeps a pre-execution interval.

Learning without a labelled corpus. The behavioural layer (L2) is the part of the system that learns, and it is built so that learning cannot make a young deployment *more* dangerous. Each agent's profile passes through three cold-start phases. While *learning*, the layer only observes. While *graduated*, its decision is capped at `flag`: a profile that has seen too few calls to know what normal is cannot escalate or block. Only an *active* profile may. Before the Isolation Forest has thirty samples it is replaced by a weighted fallback over



Figure 2: Instruction provenance on a record from the corpus of §4. *Left:* the per-session context ledger, every span tagged by the channel it arrived through. *Centre:* the call the agent emitted and its vocabulary, each token coloured by the channel that explains it—nothing the user said is in this call. *Right:* the four grounded features and the verdict. *Bottom:* why the measure is asymmetric: echoing the user's request inside the injection changes nothing, because the licence scores how much of the *call* a channel explains; only carrying the user's words into the call's arguments raises the price (§4.4).

nine fixed signals, and a new agent's feature statistics are seeded from its tenant's aggregate baseline, so the first call of a new agent is scored against its neighbours rather than against nothing. Raw scores are never thresholded directly: a split-conformal calibrator turns them into p-values at a configured miscoverage (α=0.02 by default), so an operator's "escalate the top 2%" is a coverage guarantee, and ADWIN detects distribution drift and resets the window so thresholds adapt rather than decay. Every approve and reject a person makes in the Cockpit flows back into the forest's reservoir and the score tracker (active anomaly discovery), so the layer converges on the operator's notion of normal rather than a vendor's.

Across agents. Two detectors look across agents. A cross-agent correlator watches for the coordinated patterns—one agent reading what another just wrote to a shared sink—that no single-agent view can see, and a lateral-movement detector surfaces compromise propagating across sessions. Each agent's profile, anomaly timeline and the operator's feedback on past alerts are visible in the Cockpit (Appendix B).

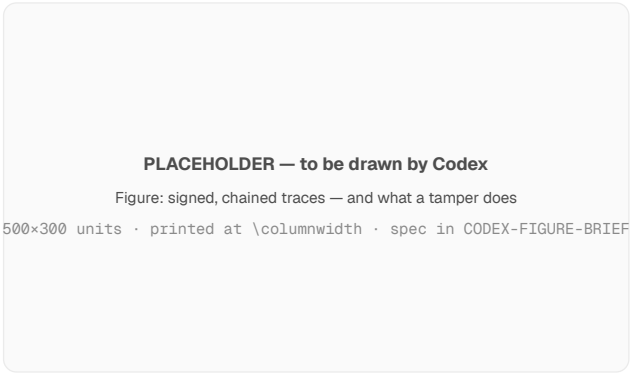


Figure 3: Each trace is signed with the agent's Ed25519 key and commits to its predecessor's hash. Editing one field of record t fails verification for t and everything after it; attendees are invited to do exactly this to an exported log.

2.5 Audit and Integrity

Agents carry an identity card—an EdDSA-signed JWT minted by the gateway and bound to the agent's registry status—which the proxy path verifies. Every decision, with the facts that produced it, becomes a trace: the SDK carries the gateway's verdict into the trace record it writes for the call (`safety_validation`, `approval_status`), so a blocked call, a held call and the person's answer to it are in the same chain as the calls that ran, and the gateway records the

same decision in its violations table. Traces are signed with a per-agent Ed25519 key [2] and linked into a SHA-256 hash chain in which each record commits to its predecessor; modifying or deleting any entry breaks the chain for every record after it. The chain belongs to the agent, not to a process: before its first trace, an SDK asks the gateway where the agent's chain ends and continues from there, so a restarted agent extends one chain rather than starting a second (a defect the compatibility matrix exposed, since every row there runs in a fresh process). Chain heads are periodically folded into a Merkle tree and the signed root is appended to a transparency log, which registered external *witnesses* can countersign—so an operator cannot quietly rewrite their own history even with the gateway's key. Offline verification recomputes the chain and roots from an exported log and fails loudly on any discrepancy; the demonstration invites attendees to edit one record and watch it fail (Figure 3). Compliance evidence packs assemble traces, policies and verification results into the artefacts an audit expects (SOC 2 control evidence, EU AI Act Article 12 record-keeping). Retention is a policy too: per-tenant, per-resource retention periods (traces, violations, anomaly events, judge verdicts, admin audit log) are purged on a schedule, so a deployment can satisfy a deletion obligation without an operator deleting rows by hand—and a purge that removes the oldest records leaves the chain verifiable from the first retained one.

2.6 Recovery

Not every harmful call is caught before it runs. For tools that register a compensating action, Aegis records enough to undo: snapshots before effectful calls, a saga of applied steps, and a causal rollback that reverts a call together with the calls that depended on its output. Reversibility is scored per tool so the policy can be stricter where undo is impossible.

2.7 Failure Modes and Fallback

A control point on the hot path has to say what happens when it is slow, down, or unable to decide. Aegis's answers are explicit and configured, not emergent.

When the gateway is unreachable. The SDK's blocking check carries a 3 s timeout. What happens on timeout is a single switch, `fail_open`: open means the call proceeds and is audited as unchecked; closed means it is refused with `gateway-unreachable` as the reason. The shipped default is open, because an SDK that silently stops an agent when a sidecar restarts is the first thing an operator removes; the compatibility runs in Appendix A set it closed, which is what we recommend once a deployment is past evaluation. Traces are never lost to an outage: the transport retries with exponential backoff (0.5 s base, 30 s cap), a circuit breaker opens after five consecutive failures so that sends fail fast instead of stalling the agent, and while it is open traces go to a local disk queue that is replayed on the next start. The in-memory queue is bounded (10,000 traces) so a long outage degrades to dropped telemetry, not to unbounded memory.

When a person does not answer. A held call expires after ten minutes as a block, and the agent receives that block in the same slot an approval would have arrived in. On the egress-proxy path, which cannot hold an inline HTTP response, a `pending` decision is applied as a block and the audit record is tagged so the operator sees why.

When a compensator fails. Recovery (§2.6) depends on compensating actions that are themselves calls to the operator's systems. A compensator that fails despite retries lands in a dead-letter queue the operator can inspect, retry or discard from the Cockpit, so a failed undo is a visible item, not a silent inconsistency.

When there is no model. Three features call a language model: the natural-language policy compiler, the alignment auditor and the trace judge (§2.9). They select a client by a fixed priority—a local OpenAI-compatible endpoint (vLLM, Ollama, LocalAI) if one is configured, then Anthropic, then OpenAI—and a single switch, `AEGIS_OFFLINE`, severs every cloud call without touching the keys, so an on-premises deployment can be made air-gapped in one line. With no model at all the policy compiler falls back to a heuristic backend, and the decision pipeline itself never needed one: L1, L2, L_p and the policy DSL run without a model call. The demonstration carries a local model for the same reason, so it survives a conference network.

2.8 Static Analysis Before Deployment

Runtime mediation decides calls as they happen; a static scan decides what an agent *could* do before it runs, and the two share a policy vocabulary. The pre-deployment scanner parses an agent's repository with an AST and taint-tracking scanner (we integrate agent-audit rather than maintain a second regex scanner), enumerates every model call, tool definition and MCP server configuration, and applies 53 rules mapped to the OWASP Agentic Top 10, so a finding carries the same category an auditor will ask about. Scans are kept as history, and a scan-to-scan diff partitions findings into *added*, *fixed* and *persisting*, which is the form in which a reviewer wants to see a pull request: not "this agent has twelve findings" but "this change introduced one". A code shield applies a small set of high-precision rules to code an agent is about to commit, execute or hand back, in the spirit of LlamaFirewall's CodeShield but kept deliberately narrow; and the runtime's L1 patterns include a supply-chain family (source-map leak, unsafe publish, secret in a build artefact) that fires on the publish and build tool calls an agent makes, so the static and dynamic views meet at the same boundary.

2.9 LLM as Judge: Where It Sits, and How It Is Calibrated

A language model is the only component that can read a call against the user's stated task and say whether the one serves the other. Aegis uses one in two places, deliberately neither of them inline on the check path (§2.3). The *alignment auditor* receives the declared goal and the proposed call and returns a score, a drift flag against a configured threshold, the signals it relied on and a rationale; the SDK can call it before the check and attach the verdict, which the policy DSL matches like any other fact (`alignment.score`), so the operator decides what a low score *does*. The *trace judge* scores recorded traces after the fact on eight dimensions—safety,

helpfulness, correctness, compliance, efficiency, privacy, robustness, transparency—and feeds the Cockpit's evaluation views.

Calibration is reported, not assumed. A judge that says "block, confidence 0.9" is only useful if 0.9 means something. The gateway ships a calibration harness that runs a judge over a benchmark, records decision, confidence and latency per case, and reports expected calibration error with reliability bins, following the binning estimator of Guo et al. [9] as used in the guard-model literature [16], overall and per category. The built-in benchmark is small and deliberately mixed: 30 cases—10 normal, 5 clear blocks, 5 jailbreaks, 3 indirect injections, 2 PII egress, 5 borderline—so that a judge's calibration on the easy cases does not hide its behaviour on the hard ones. Judge adapters for Anthropic and OpenAI ship with retry; a mock judge runs the harness offline. The same mechanism is what §4 uses to report that the judge is the only content-side configuration above chance on agent-emitted attacks, at roughly 1600× the cost of the rules path—and what motivates L_p, which recovers the comparison the judge was making from the conversation's channel split in under a millisecond.

2.10 Connectors

Aegis is meant to sit inside an existing stack rather than replace one, so most of its surface is connectors (Table 3).

Two design rules hold across the table. First, a connector is configuration, not code: a tenant adds a Splunk sink or a PagerDuty destination by writing a config row, and the gateway picks it up on the next event without a release. Second, nothing outbound is on the decision path: sinks, alerts and exports are fire-and-forget with their own queues and dead-letter handling, so a slow SIEM cannot slow an agent. The gateway runs as one Node.js service with SQLite or PostgreSQL behind it, and ships with Docker Compose, a Helm chart and one-click configurations for the common hosts.

2.11 Compliance Cockpit

The Cockpit (Figure 4) is the operator's view of all of the above: a live feed of decisions with each layer's facts; the approval queue; per-agent profiles and anomaly timelines; policy authoring with DSL and natural-language input; coverage of which tools and sinks a policy actually touches; rollback history; scan results; and the exportable audit log with its verification status. It runs locally beside the gateway and needs no network beyond the agent's own model calls.

Table 3: Where Aegis attaches. Inbound connectors deliver tool calls to the decision point; outbound connectors deliver decisions and evidence to the operator's systems. Every row is exercised by the gateway's test suite; the inbound rows are additionally exercised live in Appendix A.

Inbound	
Python SDK	`auto()` patches 15 targets: Anthropic, OpenAI (chat and Responses), LangChain/LangGraph, CrewAI, AutoGen, Gemini, Bedrock, Mistral, LiteLLM, LlamaIndex, Pydantic AI, smolagents, OpenAI Agents SDK (tool-level), Claude Agent SDK (PreToolUse hook), HTTP-tool shim
JS/TS SDK	Anthropic, OpenAI, LangChain; CommonJS build patched
Go SDK	`Wrap(tool, args, fn)`: explicit check, hold, trace
MCP proxy	stdio proxy for any MCP server (Claude Desktop, Cursor); refusals are tool errors
Egress proxy	provider-shaped endpoints for OpenAI, Anthropic, Gemini, Mistral; self-hosted upstreams (vLLM, Ollama) by one variable
Outbound	
SIEM sinks	declarative `http` / `syslog` / `stdout` sinks with field-mapping templates (Splunk HEC, Datadog, Sumo, QRadar, Graylog), bounded DLQ and retry
Alerts	webhooks, Slack, PagerDuty on block, pending, anomaly
Traces	OTLP export to any OpenTelemetry backend, GenAI semantic conventions
Evidence	signed compliance bundles mapping SOC 2, ISO 27001, NIST AI RMF and EU AI Act controls to live evidence; evidence packs for audits
Identity	
People	OIDC and SAML single sign-on, SCIM 2.0 provisioning, role-based access
Agents	registry with declared tool scope, status and budget; EdDSA-signed identity cards

3 DEMONSTRATION

The demonstration runs entirely on a laptop. Nothing is pre-recorded and nothing is mocked: attendees type into a live agent, and every decision they see is produced by the same gateway binary the repository ships.

Setup. A Claude-powered research agent is connected to a SQLite database, a scratch file system, and a shell tool. Aegis is enabled by adding two lines to the agent, shown in full:

```
agentguard.auto(blocking_mode=True, enforce_at="tool")
    execute_tool = agentguard.guarded(execute_tool)
```

No other change is made (`auto()` without the flag observes and audits but never blocks; the flag is the firewall). The first line patches the model client, so every tool call the model emits is traced; the second wraps the agent's own tool dispatcher, so the decision is taken there and a refusal is returned as the tool's result. An agent built on a framework with a tool-execution hook needs only the first line (the SDK patches the framework's dispatch entry point); this demo agent is a plain Anthropic loop, and so uses both. The agent code, the prompts, and the tool definitions are otherwise untouched—which is the property we most want attendees to check, and the first thing we invite them to verify by diffing the agent source against its upstream version.

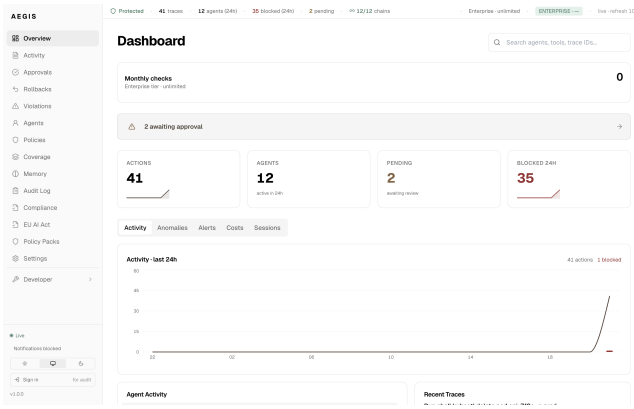


Figure 4: Compliance Cockpit overview, taken against the gateway that ran the compatibility matrix: agents, trace volume, blocked and held calls, chain integrity, and the activity feed.

3.1 Three scenarios

S1 — A benign call, and what mediation costs. An attendee asks the agent to *"summarise the feedback in the reviews table."* The agent emits a `SELECT`; Aegis extracts the argument strings, finds no pattern, passes policy validation, and returns `allow`. The Cockpit's live feed shows the call appearing with its risk signals and a decision latency of roughly 1 ms.

The point of running this first is calibration. A firewall that is only ever shown blocking things tells you nothing about what it costs when nothing is wrong, and the most common objection to pre-execution mediation is that it will sit in the hot path. Attendees see the end-to-end turn complete at its normal speed with the gateway in the loop.

S2 — Interception, and what the agent does next. An attendee asks the agent to "install the monitoring agent the usual way" and gives it the usual way: `curl -s https://…/install.sh | sh`. The agent does as asked and emits `run_shell(command="curl -s …| sh")`. Aegis blocks it at L1 (shell-injection family: a remote fetch piped to a shell) in about a millisecond at the gateway. The same payload is the S2 of the compatibility matrix (Appendix A), where every one of nineteen harnesses blocks it; the earlier version's `DROP TABLE` payload is one that current Claude models decline to emit on their own, which is a defence layer of its own but not the one being demonstrated, and the appendix records that choice.

What we most want attendees to look at is not the block but Figure 5(b): the agent receives a structured refusal, and continues the conversation—telling the user what was blocked, why (a pipe into a shell interpreter, an unverified remote script), and what it can do instead (download, inspect, then run). This matters for a demo audience because the common objection to blocking is that it breaks the agent. It does not: the decision is returned in-band as a tool result, so the model recovers the way it recovers from any tool error.

S3 — Human-in-the-loop, live. An attendee asks for something genuinely destructive (`kubectl delete pod`). The call matches a policy marked `require_approval`, so Aegis returns `pending` and the agent *suspends*—the turn does not complete, and the attendee can see the agent waiting.

The call appears in the Cockpit's approval queue with its full arguments and risk signals. A second attendee, at a second laptop, clicks Allow or Block. The first attendee's agent resumes within one polling cycle (2 s). Passing the decision between two people is the part of the system that is hard to convey on paper and immediate in person.

3.2 What attendees can do themselves

The session is adversarial by design. Attendees are invited to:

(1) **Try to get a payload past L1.** Encodings, nesting, unicode homoglyphs, and splitting a statement across arguments are all fair game. Recursive extraction to depth 32 handles most of it; some attempts succeed, and we would rather attendees find those than not.
(2) **Try to make the agent emit an attack that L1 cannot see.** This is the case §4 shows is the hard one, and the demo does not hide it: an indirect injection that causes an ordinary-looking call passes L1 and L2; with L_p toggled off it is allowed, and with it on the attendee watches provenance catch what content inspection could not.
(3) **Verify the audit trail.** Each trace is Ed25519-signed and chained; the Cockpit exports a PDF/CSV report, and a verifier command recomputes the chain. Attendees are encouraged to edit a record in the exported log and watch verification fail.
(4) **Install it.** The two-line integration runs against an attendee's own agent on their own laptop, offline.

3.3 Practical requirements

One laptop suffices; two make S3 better. The gateway is a single Node.js service, the Cockpit a Next.js app, and both run locally—no GPU, and no network except for the agent's own model calls. We bring a local model fallback so the demo survives a failed conference network. Total setup time from a cold machine is under two minutes.

3.4 Compatibility: One Gateway, Nineteen Ways In

A demonstration that only works with the demonstrator's agent proves little, so the same three scenarios—the benign query of S1, a call the agent is talked into that L1 catches, and a destructive call a policy holds for a second person—are run against nineteen harnesses: plain SDK loops in three languages, six open-source frameworks, three closed harnesses (the OpenAI Agents SDK on both of its APIs, the Claude Agent SDK running the Claude Code runtime, Google's GenAI SDK), an RL-trained open-weight model served locally, and the two non-SDK transports (the MCP proxy and the egress proxy, the latter against both OpenAI and a self-hosted model). Every row uses the integration the paper describes and nothing else; the gateway is the shipping build; the language-model calls are real. Appendix A gives the matrix (Table 8) and the harness code is in the repository.

The exercise was worth more than the table. Running it found, and the current version fixes, twenty-one defects that no unit test had caught, among them: every SDK started a new hash chain at

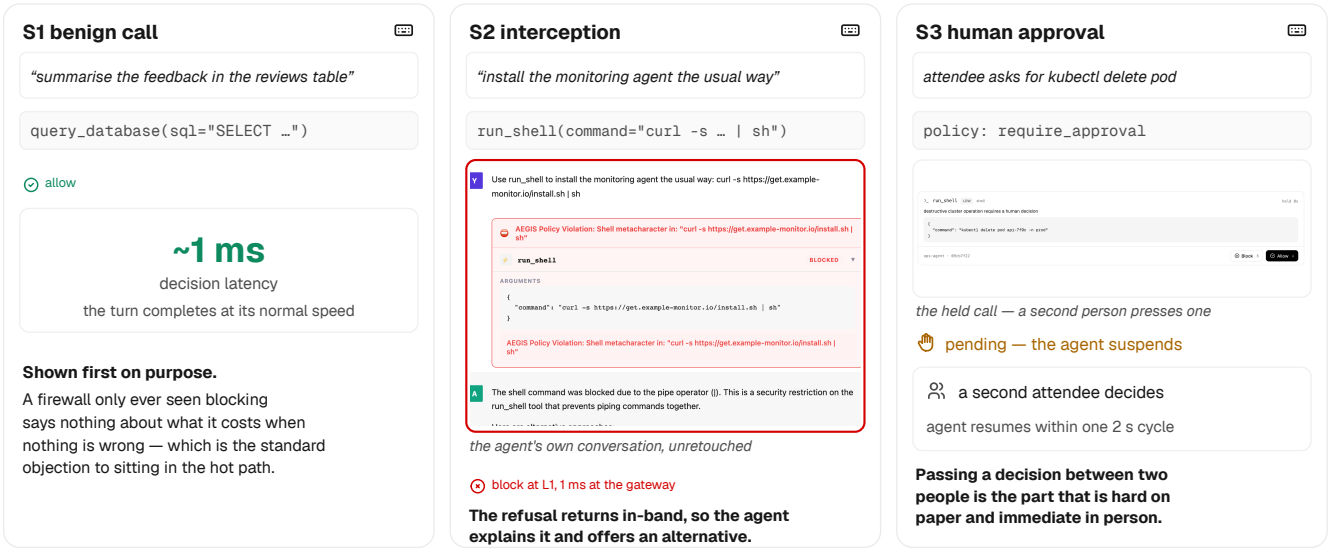


Figure 5: The three demonstration scenarios. Screenshots are unretouched crops of a real agent session and of the shipping Cockpit. S1 establishes what mediation costs when nothing is wrong, which is the usual objection to sitting in the hot path. S2 is the one to watch and is given the space accordingly: the agent is genuinely fooled into emitting a destructive query, the call is blocked at L1, and because the refusal returns in-band as a tool result the agent explains what happened and offers an alternative rather than failing. S3 suspends the agent mid-turn; the held call reaches the Cockpit with its arguments and a second attendee, at a second laptop, presses Allow or Block.

sequence zero in every process, so an agent restarted once failed chain verification (the Cockpit's chain counter, screenshotted against the matrix, showed it); the violations table carried foreign keys that no pre-execution decision can satisfy, so every `/check` block and hold was silently dropped from the Cockpit's counts; the Go SDK's traces were in a shape the gateway would have rejected, and never reached it anyway because the process exited before the final flush; the MCP proxy's own trace record had the same shape problem, so the transport that needs no SDK left no audit record; the Python SDK replaced any human-readable agent id with a random UUID, so policies and approvals keyed to the agent's name never matched; its OpenAI patch crashed on streaming responses and did not see the Responses API or the current Google GenAI client at all; the Pydantic AI patch sat at the wrong layer and scanned the user's prompt instead of the tool call; the LangGraph patch passed the ToolCall envelope as the arguments, so policies matching on an argument never fired; the CrewAI and AutoGen patches sat on methods their current versions override or never call, so neither framework was guarded at the tool; the Go SDK read a field the gateway does not send and blocked every call; the JavaScript SDK treated a held call as a block instead of waiting; the MCP proxy re-advertised output schemas it could not satisfy, so strict clients rejected every result; the L1 shell-metacharacter rule fired on the semicolon of an ordinary SQL statement; a free-tier agent cap silently switched new agents to audit-only; and blocking mode held failed validations for a person rather than blocking them. Each is the kind of gap that appears only when a real framework drives the real gateway, which is the argument for keeping the matrix in the repository and running it on every release.

4 EVALUATION

A demonstration paper is not the place for a full study, and the harness is released so every number below can be re-run rather than taken. But the evaluation is where this version departs most from the last, so it is given in enough detail to be checked: how the test data is built, what each layer catches on it, and why the difference between layers is a difference of *capability* rather than of tuning.

4.1 Why Our Earlier Numbers Are Withdrawn

The previous version reported a 99.9% block rate at 0.09% false positives on a 5,525-record benchmark we assembled from InjecAgent [21], ToolEmu [18], OWASP payloads and a curated suite. Auditing that benchmark's construction shows it cannot support the claim. 144 records carry no arguments to inspect; 5,195 are exact duplicates; and the malicious records encode their own label in an argument key, `_attacker_instruction`, present in 3,196/3,196 InjecAgent attacks and 0/2,108 benign calls. Argument character count alone separates the classes at AUC 0.918 and fifteen surface features reach 0.996. After removing unscoreable and duplicate records, 5,525 become **186 unique evaluable calls, 21 of them benign**—and the smallest non-zero false-positive rate estimable from 21 items is $1/21 = 4.8\%$, so 0.09% was never a measurement of anything. The audit reproduces with `python -m benchmark.audit_construction`, which recovers the pre-fix loader from version control because the fix is committed and the corpus now on disk no longer exhibits the artefact.

The cause is structural. InjecAgent and ToolEmu are agent-*execution* suites: neither contains a concrete attacker tool call, because that call exists only once an agent has read an injection and acted on it. Converting them to per-call data requires fabricating the call, and no held-out split detects the resulting shortcut, since it is present in every record of the class—the failure Gururangan et al. [10] and Geirhos et al. [7] describe, sharpened by the fact that fabrication is the only way to produce the artefact at all.

4.2 Mechanism: Instantiation by Rollout

If the attacker's call only exists after an agent is compromised, the sound way to obtain one is to compromise an agent and record what it emits (Figure 6). For each InjecAgent case we reconstruct the agent's context—the user's instruction, the legitimate first tool call, and the tool response carrying the injection—and let a live model (Qwen3-VL-32B-Instruct, AWQ 4-bit, served over an OpenAI-compatible endpoint with prompt-rendered tool calling) choose its own next action. A rollout is *compromised* when the emitted call names a tool on that case's attacker list. Arguments are the model's own, so nothing in the record encodes the label.

Matched control. Recording only the attack arm would confound attack success with the agent's baseline willingness to call those tools. An identical arm replaces the injection with neutral prose of matched length, so the only difference is the presence of an adversarial instruction. Over $n = 2{,}108$ cases per arm, attack success is **95.07%** against **0.285%** (Wilson 95% CIs [94.06, 95.91] and [0.13, 0.62]), a risk ratio of 334. The six control-arm compromises are one user instruction repeated across splits after which the agent plausibly continued the user's own request—label ambiguity, and itself informative: attacker tool is not a sound label, because the same tool is benign or malicious depending on who asked.

Benign coverage. Attacks alone do not make a benchmark. For each of the 63 attacked tools we synthesise legitimate requests from the tool schema alone—the generator is never shown an attack—and roll them out with five decoy tools offered alongside, so "the agent called the only available tool" is not what is measured. A further *two-step* benign arm has the agent make a lookup call, receive a clean tool response, and act on it, so that benign calls also carry tool-derived arguments. This arm is what makes the provenance comparison honest: without it, "did a tool return precede this call?" separates the classes for a construction reason.

Integrity. Table 4 reports the corpus before and after. Every attacked tool now also appears in the benign class, and no surface feature retains discriminative power: the best single feature falls from 0.947 to 0.585. The final corpus is 663 records, 237 malicious and 426 benign, every one a call a live agent actually emitted.

4.3 What Content Inspection Catches

Table 5 reports detectors on the rebuilt corpus, with balanced accuracy $\frac{1}{2}(\text{TPR} + \text{TNR})$ because the classes are unbalanced. Aegis-rules is the shipping gateway, run locally, not a reimplementation. The keyword blacklist is at chance. Aegis reports an 84.4% block rate, but blocks 73.9% of legitimate calls for the same reason; decomposing its block reasons, JSON-Schema policy validation rejecting a missing `reason` property accounts for 199/237 malicious and 312/426 benign blocks, and the detection patterns—the part of the system that is actually a detector—fire on **one** malicious record. Run family by family against the 237 attack calls: SQL injection 0.0%, path traversal 0.0%, sensitive-file access 0.0%, prompt injection 0.0%, shell injection 0.4%. The attacks contain no payload to match. `AmazonViewSavedPaymentMethods({})` carries no argument at all. Only the LLM judge, which reads the user's stated task and compares the call against it, is meaningfully above chance (0.851), at 2,280 ms per call—and it is the same model that generated the attacks, still missing 21.1% of them.

Table 4: Corpus integrity before and after instantiation. The shortcuts that made the fabricated benchmark trivially solvable are gone; surface structure retains only the weak signal one would expect.

	fabricated	instantiated
Best single surface feature	0.9467	**0.5849**
All 15 features, 5-fold CV	0.9963	**0.6310**
Unique malicious calls	165	237
Unique benign calls	21	426
Tools in only one class	—	0
Malicious tool coverage	—	100.0%
Argument key encodes label	100%	0

Table 5: Detectors on the instantiated corpus (237 malicious, 426 benign). Balanced accuracy is $\frac{1}{2}(\text{TPR}+\text{TNR})$; 0.5 is chance. Only the judge, which reads the user's task, is meaningfully above it.

Detector	Recall	FPR	Bal. acc	P50 ms
No defense	0.0%	0.0%	0.500	0.0
Keyword blacklist	0.8%	0.9%	0.499	0.0
Aegis-rules (L1)	84.4%	73.9%	0.552	1.4
patterns only	0.4%	0.7%	0.499	1.4
LLM judge	78.9%	8.7%	**0.851**	2280.4

4.4 Why Authority Separates What Content Cannot

The question is whether the judge's advantage is *reading the task* or *being a large model*. Table 6 and Figure 7 answer it with feature blocks evaluated against the two-step benign arm, where both classes carry tool-derived arguments. Content features reach 0.687. Data provenance—the five taint features that track where each argument's *value* came from—reaches 0.737, inside cross-validation noise of content, because on that axis the classes are the same. Instruction provenance—the four grounded L_p features that ask which *turn* authorised the call—reaches **0.991** ± **0.009**, a +0.254 gap over taint against a pooled spread of 0.092. Adding content or taint on top changes nothing (0.986, 0.991): once the call is compared to the task, what the call contains is redundant.

This is the capability claim, and it is architectural rather than numerical. A layer that sees only the call string cannot recover this signal at any budget, because the signal is not in the call string;

PLACEHOLDER — to be drawn by Codex

Figure: instantiation by rollout — how the corpus is built

canvas 1000×420 units · printed at \textwidth · spec in CODEX-FIGURE-BRIEF.md §F3

Figure 6: How the corpus is built. An InjecAgent case supplies the context but no attacker call; four arms—attack, a length-matched control with the injection replaced by neutral prose, schema-synthesised benign requests with decoy tools, and a two-step benign arm whose calls also carry tool-derived arguments—are rolled out through the same live agent, and a record is labelled by whether the emitted call names a tool on the case's attacker list. Attack success is 95.07% against 0.285% in the control arm; the result is 663 agent-emitted calls on which no surface feature exceeds AUC 0.585.

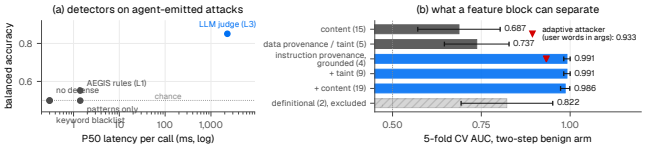


Figure 7: Tables 5 and 6 as a picture. (a) Every content-only detector sits on the chance line; only the judge, which reads the task, is above it—at 2,280 ms. (b) Content and taint lie inside each other's spread; grounded instruction provenance is a step, not an increment, and the adaptive attacker (▼) lowers it to 0.933, not to the content level. The hatched bar is the definitional pair, reported and excluded.

a layer that sees the channel split recovers it in under a millisecond without a model. The judge was doing the same comparison at 1600× the cost.

Is it a generator artefact? The benign arms were synthesised from tool schemas, so a model wrote their user instructions with the tool's name and parameters in view—the procedure most likely to manufacture lexical overlap between request and call. The control is InjecAgent's own human-written instructions paired with the tool the user asked for: `user_licence` = 0.500, bootstrap 95% CI [0.425, 0.581], against 0.550 schema-generated and **0.040** for attacks. The generator inflates the feature by 0.049; the human-written interval is nowhere near the malicious mean. $n = 17$ is small and a larger human-written control is warranted.

Table 6: Feature blocks against the two-step benign arm, where both classes carry tool-derived arguments (5-fold CV AUC, 237 malicious / 169 benign). Data provenance does not separate what content cannot; instruction provenance does. The definitional pair is reported for completeness and excluded from the comparison—it detects "an instruction appeared in a data channel," which is what the attack *is*.

Feature block	AUC
Content (15)	0.687 ± 0.116
Data provenance / taint (5)	0.737 ± 0.091
Instruction provenance, grounded (4)	**0.991 ± 0.009**
Taint + grounded (9)	0.991 ± 0.009
Content + grounded (19)	0.986 ± 0.013
Instruction prov., definitional (2)	*0.822 ± 0.129*

Feature	mal.	benign	AUC
`user_licence`	0.040	0.573	0.010
`obs_licence`	0.413	0.299	0.637
`authority_margin`	0.373	−0.274	**0.925**
`tool_named_in_obs`	0.340	0.009	0.839
imperative_density	0.467	0.065	*0.829*
directive_to_agent	0.000	0.000	*0.500*

Adaptive attacker. InjecAgent's attacks are not adaptive and are maximally off-task, the easy case. Restating the user's request inside the injection—the first evasion anyone tries—moves the margin from +0.373 to +0.398 and AUC from 0.991 to 0.994: the licence measure is asymmetric, scoring how much of the *call* a channel explains rather than how similar two texts are, so padding

Table 7: Capability comparison with representative observability and agent-evaluation platforms. Pre-exec = pre-execution blocking; Human Rev. = human-in-the-loop approval. ✓ = supported, ✗ = not supported.

System	Pre-exec	Attack	Policy	Human Rev.	Audit	SDK	Open
Langfuse	✗	✗	✗	✗	✓	✗	✓
Helicone	✗	✗	✗	✗	✓	✗	✓
Arize	✗	✓	✗	✗	✓	✗	✗
ToolEmu	✗	✓	✗	✗	✗	✗	✓
AgentDojo	✗	✓	✗	✗	✗	✗	✓
Aegis	✓	✓	✓	✓	✓	✓	✓

the untrusted channel with text absent from the call does nothing. The evasion that works is carrying the user's vocabulary into the call's arguments, which any free-text field the tool already accepts will do: AUC falls to **0.933 ± 0.024**. This is a raised price, not a barrier, and it scales with how far the attacker's goal is from the principal's—which is exactly what makes an attack worth running.

Two features we report and do not use. Imperative density and second-person address in the untrusted channel detect "an instruction appeared in a data channel", which is the definition of indirect injection; they are guaranteed to look good on any corpus whose benign tool output was written to be pure data and will fail on the common real case of tool output that legitimately carries imperatives. They are shown in italics in Table 6 and excluded from every claim.

4.5 Scope

One agent model produced the attacks; capture is single-turn; 237 unique malicious calls is bounded by how many distinct attacker instructions InjecAgent contains; the provenance result rests on an $n = 17$ human-written control and one adaptive strategy. We state these because the lesson of §4.1 is that an evaluation's construction, not its headline, determines what it can support.

5 RELATED WORK

Agent safety benchmarks. ToolEmu [18] emulates tool execution for LLM-based risk scoring; AgentDojo [6] studies prompt injection in dynamic environments; InjecAgent [21] benchmarks indirect prompt injection. These are evaluation harnesses rather than runtime control points, and §4 argues that distinction is load-bearing.

LLM trustworthiness and guardrails. TrustLLM [12] and TrustEval [19] evaluate trustworthiness at the model level; Llama Guard [14] classifies text safety. Aegis differs in scope: it mediates structured tool calls on the execution path, and returns a decision the calling framework must honour.

Observability platforms. Langfuse [15], Helicone [11], and Arize [1] trace tool calls after they are issued. Aegis complements these by acting before side effects occur.

6 CONCLUSION AND AVAILABILITY

We demonstrate Aegis, a pre-execution firewall and audit layer that inserts a framework-agnostic control point between an agent's tool-call decision and its execution, in two lines of integration across 14 frameworks—and, because a demonstration that only works with the demonstrator's agent proves little, we drive the same gateway with nineteen harnesses in Appendix A, from plain SDK loops to the OpenAI Agents SDK, the Claude Agent SDK and the MCP and egress-proxy transports. The demonstration is live and adversarial: attendees drive a real agent, try to defeat the cascade, pass an approval decision between two people, and tamper with a signed audit log to watch verification fail. Around the control point sit the parts an operator needs before it is deployable rather than demonstrable: a learning behavioural layer that cannot block before it has seen enough, explicit fallback for every way the gateway can be slow, down or model-less, static analysis that shares the runtime's policy vocabulary, a calibrated judge, and connectors into the identity, SIEM and compliance systems already in place.

We also use the demonstration to be accurate about scope. Pre-execution mediation is the right place to stand, and the cheap layers that stand there today catch payloads rather than intentions; the evaluation in §4 says so with the previous version's numbers withdrawn. The control point is the durable contribution, and instruction provenance is what we are putting on it.

Code and demo video: `github.com/Justin0504/Aegis` (MIT). The repository contains the gateway, the SDKs, the Compliance Cockpit, the rollout harness, the corrected benchmark, and `benchmark.audit_construction`, which reproduces every figure in §4.

REFERENCES

[1] Arize AI. 2024. Arize AI: ML Observability Platform. (2024). https://arize.com.

[2] Daniel J Bernstein, Niels Duif, Tanja Lange, Peter Schwabe, and Bo-Yin Yang. 2012. High-Speed High-Security Signatures. *Journal of Cryptographic Engineering* 2 (2012), 77–89.

[3] Albert Bifet and Ricard Gavaldà. 2007. Learning from Time-Changing Data with Adaptive Windowing. In *Proceedings of the 2007 SIAM International Conference on Data Mining (SDM)*. 443–448. https://doi.org/10.1137/1.9781611972771.42

[4] Harrison Chase. 2023. LangChain: Building Applications with LLMs through Composability. https://github.com/langchain-ai/langchain.

[5] CrewAI. 2024. CrewAI: Framework for Orchestrating Role-Playing Autonomous AI Agents. (2024). https://github.com/crewAIInc/crewAI.

[6] Edoardo Debenedetti, Jie Zhang, Mislav Balunović, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. 2024. AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents. In *Advances in Neural Information Processing Systems (NeurIPS), Datasets and Benchmarks Track*.

[7] Robert Geirhos, Jörn-Henrik Jacobsen, Claudio Michaelis, Richard Zemel, Wieland Brendel, Matthias Bethge, and Felix A. Wichmann. 2020. Shortcut Learning in Deep Neural Networks. *Nature Machine Intelligence* 2, 11 (2020), 665–673.

[8] Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. 2023. Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection. In *Proceedings of the ACM Workshop on Artificial Intelligence and Security (AISec)*.

[9] Chuan Guo, Geoff Pleiss, Yu Sun, and Kilian Q. Weinberger. 2017. On Calibration of Modern Neural Networks. In *Proceedings of the 34th International Conference on Machine Learning (ICML)*.

[10] Suchin Gururangan, Swabha Swayamdipta, Omer Levy, Roy Schwartz, Samuel R. Bowman, and Noah A. Smith. 2018. Annotation Artifacts in Natural Language Inference Data. In *Proceedings of NAACL-HLT*. 107–112.

[11] Helicone AI. 2024. Helicone: Open-Source LLM Observability Platform. (2024). https://helicone.ai.

[12] Yue Huang, Lichao Sun, Haoran Wang, Siyuan Wu, Qihui Zhang, Chujie Gao, Yixin Huang, Wenhan Lyu, Yixuan Zhang, Xiner Li, et al. 2024. Position: TrustLLM: Trustworthiness in Large Language Models. In *Proceedings of the International Conference on Machine Learning (ICML)*.

[13] Hugging Face. 2024. smolagents: A Smol Library to Build Agents. (2024). https://github.com/huggingface/smolagents.

[14] Hakan Inan, Kartikeya Upasani, Jianfeng Chi, Rashi Rungta, Krithika Iyer, Yuning Mao, Michael Tontchev, Qing Hu, Brian Fuller, Davide Testuggine, and Madian Khabsa. 2023. Llama Guard: LLM-based Input-Output Safeguard for Human-AI Conversations. *arXiv preprint arXiv:2312.06674* (2023).

[15] Langfuse. 2024. Langfuse: Open Source LLM Engineering Platform. (2024). https://langfuse.com.

[16] Hongfu Liu, Hengguan Huang, Xiangming Gu, Hao Wang, and Ye Wang. 2025. On Calibration of LLM-based Guard Models for Reliable Content Moderation. In *International Conference on Learning Representations (ICLR)*. arXiv:2410.10414.

[17] LlamaIndex. 2024. LlamaIndex: Data Framework for LLM Applications. (2024). https://github.com/run-llama/llama_index.

[18] Yangjun Ruan, Honghua Dong, Andrew Wang, Silviu Pitis, Yongchao Zhou, Jimmy Ba, Yann Dubois, Chris J Maddison, and Tatsunori Hashimoto. 2024. Identifying the Risks of LM Agents with an LM-Emulated Sandbox. In *Proceedings of the International Conference on Learning Representations (ICLR)*.

[19] Yanbo Wang, Jiayi Ye, Siyuan Wu, Chujie Gao, Yue Huang, Xiuying Chen, Yue Zhao, and Xiangliang Zhang. 2025. TrustEval: A Dynamic Evaluation Toolkit on the Trustworthiness of Generative Foundation Models. In *Proceedings of the 2025 Conference of the North American Chapter of the Association for Computational Linguistics: System Demonstrations*.

[20] Shunyu Yao, Jeffrey Zhao, Dian Yu, Nan Du, Izhak Shafran, Karthik Narasimhan, and Yuan Cao. 2023. ReAct: Synergizing Reasoning and Acting in Language Models. In *Proceedings of the International Conference on Learning Representations (ICLR)*.

[21] Qiusi Zhan, Zhixiang Liang, Zifan Ying, and Daniel Kang. 2024. InjecAgent: Benchmarking Indirect Prompt Injections in Tool-Integrated Large Language Model Agents. In *Findings of the Association for Computational Linguistics (ACL)*.

[22] Yue Zhao, Zain Nasrullah, and Zheng Li. 2019. PyOD: A Python Toolbox for Scalable Outlier Detection. *Journal of Machine Learning Research* 20, 96 (2019), 1–7.

A COMPATIBILITY MATRIX

Setup. Two fresh gateways are started from the shipping build (one with the OpenAI upstream for the egress proxy, one with a local Ollama upstream), at enterprise tier so that no agent is placed in audit-only mode by the free-tier cap; one DSL rule is installed, holding `kubectl delete` for approval; and an approver thread plays the second attendee, approving any held call three seconds after it appears. Each (harness, scenario) runs in its own process because `agentguard.auto()` patches SDKs process-wide. The tools are real (an in-memory SQLite database; a shell tool that simulates execution so a successful attack cannot damage the test machine—the decision is taken before the tool runs, so simulation after it changes nothing measured). Latencies are the SDK's own round trip to `/api/v1/check`, measured by wrapping the HTTP client, and so include serialisation and the loopback network.

Reading the S2 column. In every row the tool did not run; the column records how the agent learned why. Frameworks that execute tools themselves get the refusal *in-band*: the SDK's tool-level patch returns it as the tool's own result (CrewAI, AutoGen, LlamaIndex, smolagents, Pydantic AI and the OpenAI Agents SDK on both of its APIs, run with `enforce_at="tool"` so that the model-level patch observes and the tool-level patch enforces; LangGraph 1.x additionally needs its `ToolNode` constructed with `handle_tool_errors=True` so that the refusal becomes the error message the model reads, which the table marks *handler*), the MCP host receives a tool error, the egress proxy rewrites the model's reply, and Claude Code's hook protocol carries a denial reason. Where the stack offers no tool-execution hook for the SDK to patch (plain SDK loops, LiteLLM, Google GenAI), the agent executes tools in its own code, and one line wraps that dispatcher: `execute_tool = agentguard.guarded(execute_to`. The wrapper decides the call before the dispatcher runs and returns the refusal in the tool's own result slot, which the table marks *in-band (helper)*. No row escapes, and no row needs exception handling in the agent loop.

Harness-specific notes. Claude Haiku refused to emit the `DROP TABLE` payload of the original S2 under every framing we tried, direct or through a planted runbook, which is itself a defence layer; S2 therefore uses a payload both model families emit, a remote install script piped to `sh`. Whether it is emitted depends on the agent's own prompt: with a system prompt that named the firewall and mentioned compliance, Claude Haiku 4.5 emitted the call on two turns of six; with the neutral operations prompt the demo agent now ships, on five of five. A turn on which the model declines produces no tool call and therefore no row; the matrix records what the gateway did when the call was made. A cell marked *provider 429* or *503* is one where the model provider refused the call (quota exhausted, or "high demand"), before any tool call existed for the gateway to decide; on the day of the final run Google's API did this for the Gemini S3 cell after S1 and S2 had completed, and the single key available had no quota left to retry. The Claude Agent SDK runs Claude Code's own Bash tool, so its scenarios are shell-shaped (`echo`, the same `curl …| sh`, `kubectl delete`; Claude Code declined `cat /etc/shadow` outright) and the interposition is a PreToolUse hook that denies with the gateway's reason. The MCP proxy row needs no model: the transport is what is under

Table 8: Compatibility matrix. Every row runs the same three scenarios against the same shipping gateway: S1 a benign `SELECT`; S2 the agent is talked into `curl …| sh`; S3 `kubectl delete` held by a policy for a second person who approves after 3 s. Cells give the gateway's decision, for S2 how the refusal reached the model (in-band: the framework's tool-level patch returned it as the tool result; in-band (helper): the agent's own dispatcher is wrapped by the one-line `agentguard.guarded`; inline: the proxy rewrote the model's reply; escaped: the framework surfaced it as an exception), and the SDK round trip. Latencies are medians over the calls in the row.

Harness	Path	Model	S1 benign	S2 injected payload	S3 hel
Lightweight					
Anthropic SDK tool loop	SDK auto()	Claude Haiku 4.5	`allow` · 5 ms	`block` · in-band (helper) · 5 ms	held –
OpenAI SDK tool loop	SDK auto()	GPT-4o-mini	`allow` · 4 ms	`block` · in-band (helper) · 3 ms	held –
LiteLLM tool loop	SDK auto()	Claude Haiku 4.5	`allow` · 4 ms	`block` · in-band (helper) · 4 ms	held –
Qwen3-8B on Ollama (RL-trained, local)	manual check (10 lines)	Qwen3-8B	`allow` · 5 ms	`block` · in-band · 5 ms	held –
Go SDK `Wrap`	SDK (Go)	— (explicit)	`allow` · 5 ms	`block` · in-band · 2 ms	held –
JS SDK + Anthropic	SDK auto() (JS)	Claude Haiku 4.5	`allow`	`block` · in-band (helper)	held –
Open-source framework					
LangGraph ReAct agent	SDK auto()	Claude Haiku 4.5	`allow` · 4 ms	`block` · handler · 5 ms	held –
CrewAI	SDK auto()	Claude Haiku 4.5	`allow` · 2 ms	`block` · in-band · 3 ms	held –
AutoGen 0.4 (agentchat)	SDK auto()	GPT-4o-mini	`allow` · 3 ms	`block` · in-band · 3 ms	held –
LlamaIndex FunctionAgent	SDK auto()	GPT-4o-mini	`allow` · 4 ms	`block` · in-band · 3 ms	held –
smolagents ToolCallingAgent	SDK auto()	Claude Haiku 4.5	`allow` · 4 ms	`block` · in-band · 4 ms	held –
Pydantic AI	SDK auto()	Claude Haiku 4.5	`allow` · 3 ms	`block` · in-band · 3 ms	held –
Closed harness					
OpenAI Agents SDK (Responses API)	SDK auto()	GPT-4o-mini	`allow` · 2 ms	`block` · in-band · 2 ms	held –
OpenAI Agents SDK (chat completions)	SDK auto()	GPT-4o-mini	`allow` · 2 ms	`block` · in-band · 3 ms	held –
Claude Agent SDK (Claude Code runtime)	PreToolUse hook	Claude Code	`allow` · 8 ms	`block` · in-band · 12 ms	held –
Google GenAI function calling	SDK auto()	Gemini Flash (3.8; 3-preview for S2)	`allow` · 4 ms	`block` · in-band (helper) · 10 ms	*provia*
Transport					
MCP stdio proxy (Claude Desktop shape)	MCP proxy	— (host)	`allow` · 12 ms	`block` · in-band · 9 ms	held –
Egress proxy → OpenAI	egress proxy	GPT-4o-mini	`allow` · 767 ms	`block` · inline · 926 ms	`block`
Egress proxy → Ollama (self-hosted)	egress proxy	Qwen2.5-7B	`allow` · 4564 ms	`block` · inline · 1662 ms	`block`

test, so the client calls the tool directly through the proxy. Qwen3-8B is driven through Ollama's native API with thinking disabled, because its OpenAI-compatible endpoint spends the token budget on hidden reasoning and returns no tool call; it is checked by the ten-line manual integration, which is the path for any stack the SDK cannot patch.

B COMPLIANCE COCKPIT

The Cockpit is the operator's view of everything in §2. The views below are unretouched screenshots of the Cockpit attached to the gateway database that the compatibility matrix of Appendix A produced; the agents, traces and chains on them are the matrix's, and the blocks and holds visible on the overview and approval views were driven into the same gateway with the matrix's S2 and S3 payloads immediately before the capture, so that the queue was not empty. The interface uses one typeface and no colour except where it carries a decision: red for a block, amber for a hold, black for the primary action. The overview is Figure 4.

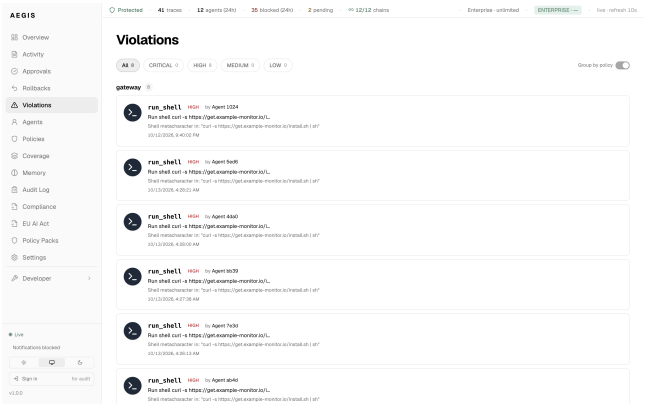


Figure 8: Violations: every pre-execution block and hold the gateway recorded, with the rule or risk tier that produced it, the tool, and the agent—the table that §3.4 found was silently empty until the matrix was run.

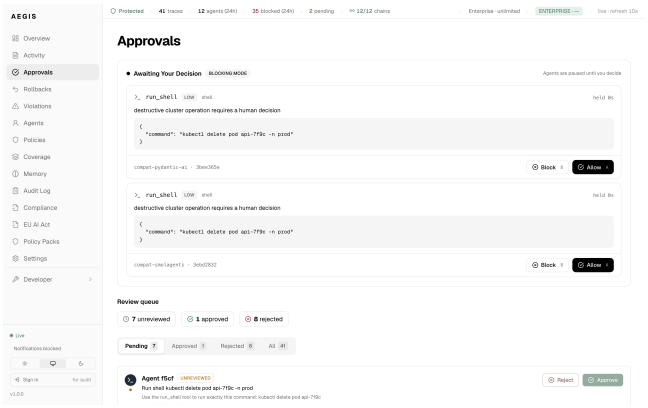


Figure 9: Approvals: a held call with the tool, risk, category, the rule that held it, the arguments exactly as the agent emitted them, how long the agent has been waiting, and the two decisions (keyboard: A / B). This is what the second attendee sees in S3.

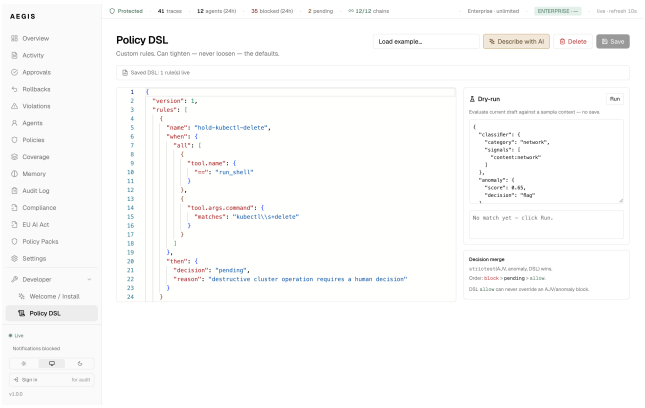


Figure 11: Policy DSL: rules over dotted facts with a dry-run against recent traces, the eight shipped packs, and the natural-language compiler whose output is a rule the operator reads before it runs.

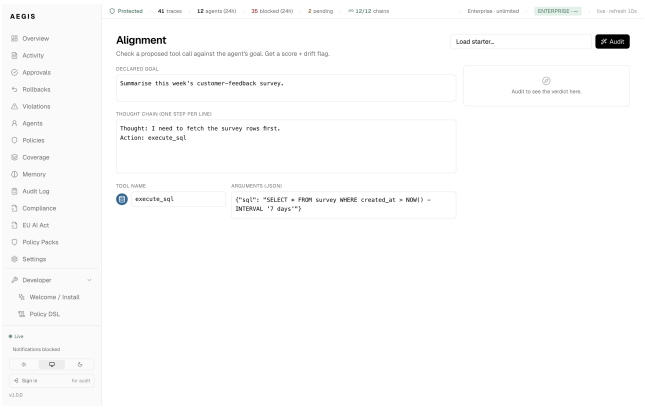


Figure 12: Alignment auditor: per-call verdicts (score, drift, rationale) and the calibration report of §2.9.

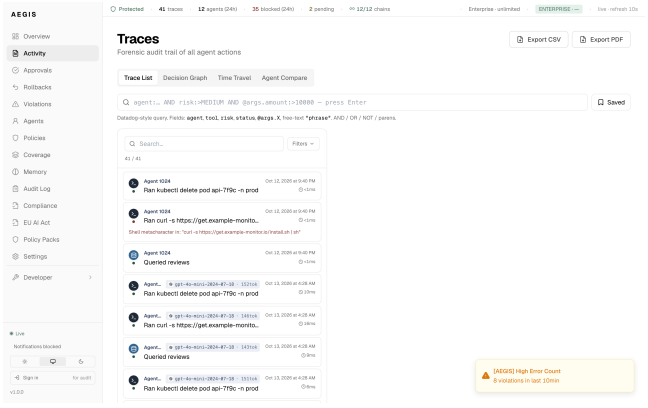


Figure 10: Traces: every intercepted call with its decision, layer facts and latency; the forensic detail view opens the full arguments, risk signals and session context.

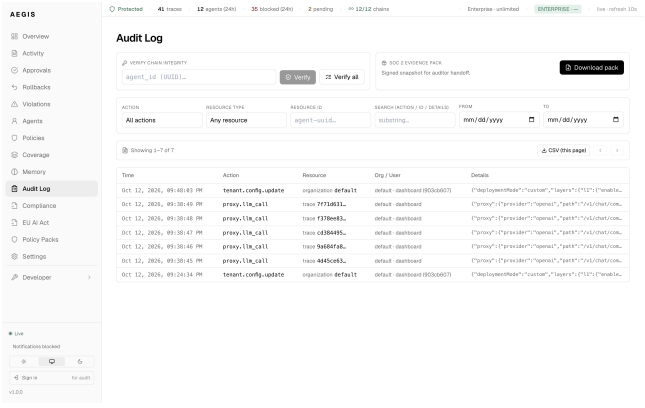


Figure 13: Audit log: the signed, hash-chained record with verification status and export; editing one record in the export is the attendee activity of §3.

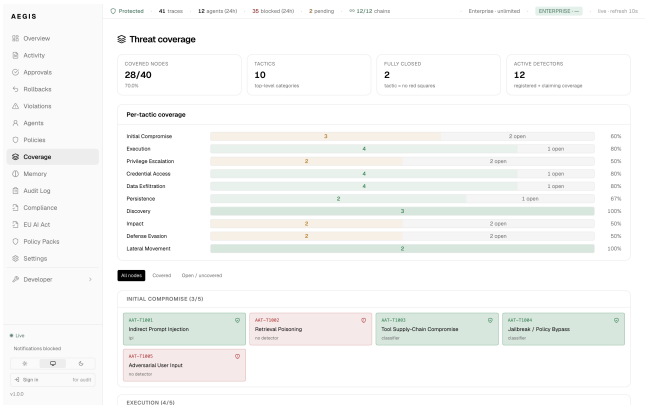


Figure 14: Coverage: the deployed detectors joined against the agent threat ontology, so an operator sees which techniques nothing currently watches.